DDoS Security Assistant Report

Indicateurs d'une attaque DDoS (IOCs)

Introduction

Signaux d'alerte et indices techniques permettant d'identifier de manière certaine qu'une infrastructure subit une attaque DDoS.

Fiche Technique

Indicateur	Cause probable	Type de DDoS associé
Trafic UDP 123 massif	Réflexion/Amplification NTP	Volumétrique
Connexions à l'état SYN_RECV	Inondation de paquets SYN	Protocolaire
Erreurs HTTP 504 en boucle	Serveurs backend saturés	Applicatif
Requêtes NXDOMAIN DNS	Inondation de résolutions aléatoires	Applicatif DNS

Explications détaillées

Principe et Fonctionnement

Reconnaître rapidement une attaque DDoS évite de perdre du temps à chercher des pannes matérielles ou des bugs applicatifs. Les analystes réseau s'appuient sur un ensemble d'indicateurs de compromission (IOCs) et d'anomalies de performance pour qualifier l'attaque.

Protocoles réseau importants et vulnérabilités DDoS

Introduction

Certains protocoles possèdent des faiblesses structurelles que les attaquants exploitent pour mener des attaques DDoS. L'étude de ces protocoles permet de comprendre comment ils sont détournés.

Explications détaillées

1. DNS (Domain Name System)

Traduit les domaines en IP (UDP 53). - **Vulnérabilité** : Fonctionne sur UDP, permettant l'IP Spoofing. - **Détournement (Amplification)** : Envoi de petites requêtes (ANY) avec l'IP usurpée de la victime à des résolveurs ouverts. Les serveurs répondent massivement à la victime.

2. NTP (Network Time Protocol)

Synchronise les horloges (UDP 123). - **Détournement (Amplification)** : La commande `monlist` renvoie la liste des 600 dernières IP. Une petite requête génère une réponse massive envoyée à la victime.

Explications détaillées

Principe et Fonctionnement

Dans le cadre d'une cyberattaque classique (ex: malware ou intrusion), l'éradication consiste à supprimer le code malveillant des machines infectées. Face à un DDoS (attaque externe), l'éradication prend une autre forme : elle consiste à s'assurer que l'attaque est totalement étouffée, que les sources malveillantes sont bloquées, et que les failles ou faiblesses d'infrastructure exploitées (ex: serveurs NTP internes mal configurés participant à l'attaque) sont corrigées.

Fonctionnement général d'une attaque DDoS

Introduction

Pour contrer efficacement une attaque DDoS, il est essentiel de comprendre son fonctionnement interne. Le mécanisme repose sur l'exploitation des limites de capacité physiques et logiques des infrastructures informatiques, associées à une coordination rigoureuse des sources d'attaque.

Explications détaillées

1. La phase de préparation : Construction du Botnet

Avant de lancer une attaque, l'attaquant doit réunir une puissance de frappe suffisante. 1. **Le Scan** : Des scripts automatisés parcourent Internet à la recherche de systèmes vulnérables (systèmes non patchés, objets connectés avec mots de passe par défaut). 2. **L'Infection** : Une fois la faille identifiée, un malware (botnet agent) est injecté sur la machine cible. 3. **L'Enrôlement** : La machine infectée (le "bot") se connecte au serveur de Command & Control (C2) de l'attaquant et attend les instructions.

Gestion des attaques DDoS

Introduction

La gestion d'une attaque DDoS nécessite une approche globale, prenant en compte les aspects techniques, opérationnels et stratégiques. Voici quelques éléments clés pour gérer efficacement ces attaques :

1. La prévention : Sécurisation des systèmes

- **Mise à jour régulière** : Assurez-vous que vos systèmes sont à jour avec les dernières mises à jour de sécurité. - **Configuration sécurisée** : Configrez vos serveurs et vos réseaux pour éviter les vulnérabilités.

2. La détection : Surveillance des trafics

- **Système de détection d'intrusion (IDS)** : Installez un IDS pour détecter les tentatives d'attaque. - **Analyse des logs** : Analysez vos journaux de sécurité pour identifier les activités suspectes.

3. La riposte : Éradication de l'attaque

- **Blocage des sources malveillantes** : Bloquez les IP et les ports utilisés par les attaquants. - **Réduction du trafic** : Réduisez le trafic en utilisant des mécanismes de réduction de charge (ex: rate limiting). - **Restauration de la normalité** : Une fois l'attaque éradiquée, assurez-vous que vos systèmes sont restaurés à leur état normal.

En résumé, la gestion d'une attaque DDoS nécessite une approche globale et une compréhension profonde des mécanismes de ces attaques. En prenant des mesures pour prévenir, détecter et riposter contre les attaques, vous pouvez réduire significativement l'impact de ces menaces sur vos systèmes et votre organisation.